



THREAT HUNT INCIDENT REPORT

HUNT 03 — OPERATION: SIGNALS BEFORE THE NOISE

Organization: PHTG | Target Device: azwks-phtg-02 | Hunt Period: Dec 9 – 23, 2025

Threat Level: CRITICAL | 38 Flags Captured | Attacker: Uruguay / 173.244.55.0/24

Malware: Meterpreter (Trojan:Win32/Meterpreter.RPZ!MTB) | C2: 173.244.55.130:4444

CLASSIFICATION: CONFIDENTIAL — FOR CISO EYES ONLY

1. EXECUTIVE SUMMARY

What Happened — Plain English for Leadership

A PHTG cloud engineer posted a photo on LinkedIn showing their workstation with the Azure portal open. That single photo exposed the name and public IP address (74.249.82.162) of an internet-facing Windows VM — azwks-phtg-02. An attacker based in Uruguay found it, ran automated scans, brute-forced the RDP password on the generic admin account 'vmadminusername', and dropped a Meterpreter backdoor. The attacker then disabled Windows Defender's active protection, renamed the malware to mimic a legitimate internal service (HealthCloud), and established a persistent C2 channel. PHTG is currently compromised.

Root cause: One LinkedIn post. One weak admin password. One publicly exposed VM. Full network foothold.

38

FLAGS CAPTURED

57

RDP SCANNER IPs

675

AUTH ATTEMPTS

23

SUCCESSFUL LOGINS

2. REPORT METADATA

Participant

Threat Hunter — PHTG Security Operations

Date

December 2025 (Hunt Period: Dec 9 - 23, 2025)

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
Hunt Name	Hunt 03 - Operation: Signals Before the Noise	
Target Organization	PHTG (fictional) - US-based, no international workforce	
Target Device	azwks-phtg-02 Public IP: 74.249.82.162 OS: Windows 10 Enterprise	
Threat Actor	Unknown APT - Uruguay-based infrastructure (173.244.55.0/24)	
Flags Captured	38 / 38 - Full Kill Chain Documented	
Classification	CONFIDENTIAL - For CISO Review Only	

3. PLATFORMS & LANGUAGES LEVERAGED

PLATFORMS	LANGUAGES & TOOLS
- Microsoft Defender for Endpoint (MDE) DeviceNetworkEvents, DeviceLogonEvents, DeviceProcessEvents, DeviceFileEvents, DeviceEvents - Microsoft Sentinel (Log Analytics Workspace) Workspace: law-cyber-range - Azure Portal VM management, NSG, networking configuration review - Windows 10 Enterprise (Target OS) East US 2, Zone 1 Created: Dec 10, 2025	- KQL (Kusto Query Language) Primary investigation language for all telemetry queries - ipv4_lookup() + externaldata() GeoIP enrichment via MaxMind GeoIP2 CSV dataset - make_set() / set_has_element() ActionType correlation for scanner detection (Q09) - SHA256 hash tracking across tables Payload lineage via InitiatingProcessSHA256

4. SCENARIO

Background

PHTG, a US-based company with no international workforce, deployed an internal endpoint health service called HealthCloud on December 11, 2025. The service installed scheduled PowerShell tasks, background service executables, and created a diagnostic cache directory under C:\ProgramData\PHTGHealthCloud - all expected and by design.

Trigger: A cloud engineer on the PHTG team published a post on LinkedIn celebrating their first day working on the new internal service. The photo attached showed their workstation with the Azure management portal open, displaying the live configuration of VM azwks-phtg-02 - including its public IP address 74.249.82.162, OS version, and subscription name. This single image became the root cause of the compromise.

An unknown threat actor operating from Uruguay-based infrastructure (173.244.55.0/24) identified the exposed IP, scanned port 3389, brute-forced the admin account 'vmadminusername', gained interactive RDP access, deployed a Meterpreter payload, bypassed Windows Defender by switching it to passive mode, and established persistent command-and-control by masquerading the malware as a HealthCloud service binary.

5. KEY OBSERVATIONS

#	Category	Observation
1	OSINT via LinkedIn Post <i>Initial Vector</i>	A PHTG employee post exposed the Azure portal showing VM azwks-phtg-02 with public IP 74.249.82.162. No phishing or social engineering needed - the attacker was handed the target.
2	RDP Port 3389 Open to Internet <i>Attack Surface</i>	Port 3389 reachable globally with no NSG restriction. 57 unique scanner IPs from 11 countries confirmed the port live within the 14-day hunt window.
3	Generic Admin Account Brute-Forced <i>Credential Weakness</i>	Account 'vmadminusername' was guessed after 637 failed attempts. InvalidUserNameOrPassword was the failure reason in 98.6% of cases - pure password spraying.
4	RDP Session from Uruguay Confirmed <i>Initial Access</i>	173.244.55.131 first logon at 05:47 UTC Dec 12. 173.244.55.128 established full RemoteInteractive desktop session at 13:32 UTC same day.
5	Security-Relevant Document Accessed <i>Data Access</i>	notes_sarah.txt opened from PHTG Documents folder. Filename matches attacker source device 'sarah-che' - suggests targeted access for credentials or operational intelligence.
6	ngrok Tunnel Bypassed URL Filtering <i>Payload Delivery</i>	Meterpreter payload downloaded via ngrok (https://unresuscitating-donnette-smothery.ngrok-free.dev/). Defender quarantined 3 times in active mode before being disabled.
7	Defender Switched to Passive Mode <i>AV Bypass</i>	At 14:18 UTC Dec 12, Defender changed from active (blocking) to passive (detection-only). This single change enabled all subsequent payload execution.
8	Double-Extension + Service Name Spoofing <i>Masquerading</i>	Rename chain: Sarah_Chen_Notes.exe.Txt -> Sarah_Chen_Notes.exe -> PHTG.exe in HealthCloud directory. Same SHA256 throughout. Classic identity theft of a legitimate service.
9	Launch.bat Persistence in HealthCloud Dir <i>Persistence</i>	cmd.exe /c C:\ProgramData\PHTGHealthCloud\Launch.bat provides automated PHTG.exe re-execution. Attacker exploited newly-deployed HealthCloud as cover.
10	Meterpreter Shell Active on Port 4444 <i>Active C2</i>	3 confirmed C2 callbacks to 173.244.55.130:4444 - same /24 subnet as RDP IPs. Full Meterpreter shell. Non-standard port avoids web proxy inspection. Compromise is ongoing.

6. MITRE ATT&CK TTP MAPPING

The following ATT&CK techniques were observed across the attack chain:

Phase	Technique ID	Technique Name	Observed Evidence
Reconnaissance	T1591.002	Gather Victim Identity Information: Email Addresses	LinkedIn post exposed employee + Azure infrastructure details
Reconnaissance	T1596	Search Open Technical Databases	Azure portal screenshot revealed public IP, VM name, OS version
Initial Access	T1078.001	Valid Accounts: Default Accounts	Generic account 'vmadminusername' brute-forced; 637 failed attempts before success
Initial Access	T1110.001	Brute Force: Password Guessing	675 RDP auth attempts; FailureReason = InvalidUserNameOrPassword (637)
Initial Access	T1021.001	Remote Services: Remote Desktop Protocol	RDP (port 3389) exposed to internet; 23 successful logons from Uruguay
Execution	T1204.002	User Execution: Malicious File	Attacker manually executed Sarah_Chen_Notes.exe via explorer.exe
Execution	T1059.003	Command and Scripting Interpreter: Windows Command Shell	cmd.exe /c Launch.bat used to execute PHTG.exe in Phase 2
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools	Defender switched from active to passive mode — blocked quarantine
Defense Evasion	T1036.003	Masquerading: Rename System Utilities	Payload renamed: .Txt → .exe → PHTG.exe (mimics HealthCloud service)
Defense Evasion	T1027.002	Obfuscated Files: Software Packing / Double Extension	Sarah_Chen_Notes.exe.Txt — double extension to hide true file type
Discovery	T1083	File and Directory Discovery	Attacker opened multiple PHTG documents; accessed notes_sarah.txt
Command & Control	T1095	Non-Application Layer Protocol	Meterpreter C2 on port 4444 (non-standard, avoids 80/443 inspection)
Command & Control	T1572	Protocol Tunneling (ngrok)	Payload downloaded via ngrok tunnel to bypass network inspection
Persistence	T1543.003	Create or Modify System Process: Windows Service	PHTG.exe placed in HealthCloud dir; Launch.bat provides persistent execution

Persistence	T1574.010	Hijack Execution Flow: Services File Permissions Weakness	Attacker hijacked HealthCloud directory (legitimate service, Dec 11) for persistence
Collection	T1005	Data from Local System	notes_sarah.txt opened — internal security-relevant content accessed

7. ATTACK TIMELINE

Chronological reconstruction of the full kill chain from OSINT leak to persistent access.

Date/Time (UTC)	Phase	Event
Dec 10 03:08 AM	Setup	VM azwks-phtg-02 created in Azure East US 2. Public IP 74.249.82.162 attached directly — no Bastion, no VPN, no NSG restricting RDP.
Dec 11 (Prior)	OSINT Leak	PHTG employee posts LinkedIn photo of workstation. Azure portal visible on screen — VM name, public IP, OS version, and subscription name all readable.
Dec 9–23 Continuous	Scanning	Internet scanners begin probing port 3389. 57 unique IPs from 11 countries identified with both ConnectionAttempt and InboundConnectionAccepted events.
Dec 12 05:47 AM	First Auth	173.244.55.131 (Uruguay) achieves first successful NTLM logon from device 'sarah-che'. Account: vmadminusername. LogonType: Network.
Dec 12 01:32 PM	RDP Session	173.244.55.128 (Uruguay) establishes full RemoteInteractive RDP desktop session. Attacker has graphical access.
Dec 12 01:35 PM	Recon	notepad.exe opened — first human interaction. Attacker browses Documents\PHTG folder. Opens notes_sarah.txt (security-relevant internal content).
Dec 12 02:11 PM	Payload DL	Meterpreter payload downloaded via ngrok: Sarah_Chen_Notes.Txt. Defender detects as Trojan:Win32/Meterpreter.RPZ!MTB and quarantines 3 times (14:11, 14:12, 14:17).
Dec 12 02:18 PM	AV Bypass	CRITICAL: Defender switched to passive mode. Active blocking disabled. Same payload renamed to Sarah_Chen_Notes.exe.Txt then Sarah_Chen_Notes.exe and executes.
Dec 12 02:19 PM	C2 Active	Sarah_Chen_Notes.exe calls back to 173.244.55.130:4444. Meterpreter C2 channel established. Attacker has remote shell.
Dec 13 10:14 AM	Staging	Payload copied to C:\ProgramData\PHTG\HealthCloud\ — the legitimate HealthCloud service directory (rolled out Dec 11). File renamed Sarah_Chen_Notes.exe → PHTG.exe.
Dec 13 10:16 AM	Persistence	Launch.bat created in HealthCloud directory. cmd.exe launches PHTG.exe via the batch file. Persistence mechanism active.
Dec 13 10:22 AM	Phase 2 C2	PHTG.exe calls back to 173.244.55.130:4444. C2 confirmed active in stealth mode, masquerading as internal service.

8. INDICATORS OF COMPROMISE (IOCs)

Type	Value	Context	Severity
IP Address	173.244.55.128	RDP attacker Phase 1 (Uruguay)	CRITICAL
IP Address	173.244.55.131	RDP attacker Phase 1 (Uruguay)	
IP Address	173.244.55.130	Meterpreter C2 — port 4444	
SHA256	224462ce5e3304e3fd0875eeabc829810a894911e3d4091d 4e60e67a2687e695	Meterpreter payload (all names)	
Filename	Sarah_Chen_Notes.exe.Txt	Double-ext evasion — initial drop	HIGH
Filename	Sarah_Chen_Notes.exe	Phase 1 execution name	HIGH
Filename	PHTG.exe	Phase 2 masquerading name	CRITICAL
File Path	C:\ProgramData\PHTG\HealthCloud\PHTG.exe	Payload final location	CRITICAL
File Path	C:\ProgramData\PHTG\HealthCloud\Launch.bat	Persistence launcher	CRITICAL
URL	https://unresuscitating-donnette-smothery.ngrok-free.dev/	ngrok payload delivery URL	HIGH
Account	vmadminusername	Brute-forced admin account	HIGH
Device	azwks-phtg-02 / 74.249.82.162	Compromised Azure VM	HIGH
Port	4444 / TCP	Meterpreter C2 port	HIGH

9. DETAILED FLAG FINDINGS — ALL 38 FLAGS

Each flag includes: answer, MITRE ATT&CK mapping, KQL query used, telemetry result, and remediation guidance.

PHASE 1 — PUBLIC EXPOSURE & OSINT RECONNAISSANCE

F00	What is the name of the fictional company under investigation?	INFO	ANSWERED
ANSWER	PHTG		
MITRE	T1591 — Gather Victim Org Information		
ANALYSIS	<i>Mission briefing confirmation. PHTG is the organization whose Azure infrastructure was exposed via a LinkedIn post.</i>		
KQL QUERY	<pre>-- No KQL required. -- Answer confirmed from mission briefing document.</pre>		
RESULT	PHTG		
REMEDIATION	Implement OSINT awareness training. Ensure all staff understand that internal tool screenshots should never be posted publicly.		

F01	What is the name of the Azure virtual machine?	INFO	ANSWERED
ANSWER	azwks-phtg-02		
MITRE	T1596.005 — Search Open Technical Databases: Scan Databases		
ANALYSIS	<i>VM name was directly readable from the LinkedIn photo — Azure portal breadcrumb and Computer name field both visible. This anchors all subsequent telemetry queries.</i>		
KQL QUERY	<pre>-- No KQL required. -- VM name visible in Azure portal screenshot from LinkedIn post.</pre>		
RESULT	azwks-phtg-02		
REMEDIATION	Enforce social media policy prohibiting screenshots of internal tooling. Use DLP solutions to detect Azure portal screenshots before sharing.		

F02	What public IP address is associated with this VM?	MEDIUM	ANSWERED
ANSWER	74.249.82.162		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
MITRE	T1596 — Search Open Technical Databases T1590.005 — Gather Victim Network Information: IP Addresses	
ANALYSIS	Public IP directly visible in two locations in the screenshot — Essentials pane and Networking panel. This is the most actionable piece of information for a threat actor: a routable address to target.	
KQL QUERY	<pre>-- No KQL required. -- Public IP visible in Azure portal Networking section of screenshot.</pre>	
RESULT	74.249.82.162	
REMEDIATION	Remove public IP from VM. Use Azure Bastion for admin access. If public IP is required, restrict with NSG rules to known admin IPs only.	

F03	What specifically makes this exposure actionable for a threat actor?	MEDIUM	ANSWERED
ANSWER	D — A public IP address is visible and associated with the virtual machine		
MITRE	T1590.005 — Gather Victim Network Information: IP Addresses		
ANALYSIS	<i>OS, size, region and tags are reconnaissance data. The public IP is what turns passive information into an active attack vector. Without a routable IP, the attacker cannot initiate contact.</i>		
KQL QUERY	<pre>-- Multiple choice analysis — no KQL required.</pre>		
RESULT	<pre>Answer: D Public IP = direct reachability = actionable attack surface</pre>		
REMEDiation	Conduct Azure Policy audit — alert on any VM receiving a public IP. Enforce private-only networking as default for internal workloads.		

F04	What activity does the LinkedIn photo depict?	INFO	ANSWERED
ANSWER	C — Managing cloud infrastructure resources		
MITRE	T1591.002 — Gather Victim Identity Information		
ANALYSIS	<i>Left monitor clearly shows Azure VM management portal (dark UI, VM details pane). Not Grafana dashboards (D) or source code (A).</i>		
KQL QUERY	<pre>-- Visual analysis of LinkedIn post — no KQL required.</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
RESULT	Azure portal open → C (Managing cloud infrastructure)		
REMEDIATION	Security awareness training on OSINT risks. Establish a 'screenshot review' policy before any infrastructure-related social media posts.		

F05	Which telemetry source best detects scanning/enumeration of the public IP?	INFO	ANSWERED
ANSWER	D — Azure network or platform analytics related to inbound connections		
MITRE	T1595.001 — Active Scanning: Scanning IP Blocks		
ANALYSIS	NSG flow logs and Azure Monitor capture all inbound traffic at the network level — including probes that never reach the OS. Windows event logs (A) only see what the OS processes.		
KQL QUERY	-- Multiple choice analysis — no KQL required.		
RESULT	Answer: D — NSG Flow Logs / Azure Monitor network data		
REMEDIATION	Enable NSG Flow Logs and Azure Monitor for all internet-facing VMs. Configure alerts for high-volume inbound connection attempts on port 3389.		

PHASE 2 — SCANNING TELEMETRY

F06	Which local port shows the strongest indicator of broad automated scanning?	HIGH	ANSWERED
ANSWER	3389 (RDP)		
MITRE	T1595.001 — Active Scanning: Scanning IP Blocks T1021.001 — Remote Services: Remote Desktop Protocol		
ANALYSIS	Port 3389 (RDP) had 173 unique source IPs — the broadest scanning footprint. Automated internet scanners (Shodan, Masscan, Censys) continuously probe RDP on publicly routable IPs.		
KQL QUERY	<pre>DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where ActionType in ("InboundConnectionAccepted", "ConnectionAttempt") summarize attempt_count = count(), unique_sources = dcount(RemoteIP) by LocalPort order by unique_sources desc</pre>		
RESULT	LocalPort attempt_count unique_sources		

PHTG // THREAT HUNT 03 // CONFIDENTIAL			azwks-phtg-02 Dec 2025	
	<pre>3389 194 173 -- Port 3389 had the most unique source IPs — signature of internet-wide scanning.</pre>			
REMEDIATION	Immediately remove public IP from VM. Place RDP behind Azure Bastion or VPN. Apply NSG rule to block all inbound 3389 from internet. Enable MFA on all RDP-capable accounts.			

F07	How many total network events targeted port 3389?	HIGH	ANSWERED
ANSWER	194 events		
MITRE	T1595.001 — Active Scanning		
ANALYSIS	194 connection events on port 3389 across the hunt window — sustained, automated scanning activity consistent with global RDP honeypot exposure.		
KQL QUERY	<pre>DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where ActionType in ("InboundConnectionAccepted", "ConnectionAttempt") summarize event_count = count(), unique_sources = dcount(RemoteIP) by LocalPort order by event_count desc</pre>		
RESULT	<pre>LocalPort event_count unique_sources 3389 194 173 -- 194 events across 14-day window.</pre>		
REMEDIATION	Configure Azure Sentinel alert: >10 unique source IPs on port 3389 within 1 hour → HIGH priority incident.		

F08	How many unique public source IPs targeted the exposed service?	HIGH	ANSWERED
ANSWER	173 unique IPs		
MITRE	T1595.001 — Active Scanning: Scanning IP Blocks		
ANALYSIS	173 distinct IPs probed RDP — typical of internet-wide scanner infrastructure. These are not targeted attacks; they are automated bots that continuously scan the entire IPv4 space.		
KQL QUERY	<pre>DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where ActionType in ("InboundConnectionAccepted", "ConnectionAttempt") where LocalPort == 3389 summarize unique_source_IPs = dcount(RemoteIP)</pre>		
RESULT			

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
	unique_source_IPs 173		
REMEDIATION	Block known scanner IP ranges (Shodan, Censys, Shadowserver) via NSG. Enroll in threat intelligence feed for proactive IP blocklisting.		

F09	How many source IPs show both a connection attempt AND an accepted connection?	HIGH	ANSWERED
ANSWER	57 IPs — confirmed TCP-responding scanners		
MITRE	T1595.001 — Active Scanning T1046 — Network Service Discovery		
ANALYSIS	57 IPs received a TCP handshake response — these are a higher-confidence attacker class. They confirmed the service is reachable and likely added this IP to targeted brute-force lists.		
KQL QUERY	<pre>DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where LocalPort == 3389 summarize ActionTypes = make_set(ActionType) by RemoteIP where set_has_element(ActionTypes, "ConnectionAttempt") and set_has_element(ActionTypes, "InboundConnectionAccepted") count</pre>		
RESULT	<pre>count_ 57 -- 57 IPs confirmed port is live and responsive.</pre>		
REMEDIATION	Treat all 57 IPs as confirmed hostile. Block at NSG level. Cross-reference with threat intelligence for known attacker infrastructure.		

F10	How many distinct countries are associated with RDP scanning activity?	MEDIUM	ANSWERED
ANSWER	11 countries		
MITRE	T1595.001 — Active Scanning		
ANALYSIS	Scanning originated from 11 countries — consistent with globally distributed botnet or VPN/proxy infrastructure. Single-country blocking is ineffective against this pattern.		
KQL QUERY	<pre>let GeoTable = externaldata(network:string, geoname_id:long, continent_code:string, continent_name:string, country_iso_code:string, country_name:string) [@"https://raw.githubusercontent.com/datasets/geoip2- ipv4/main/data/geoip2-ipv4.csv"] with (format="csv"); let rdp_scanners = DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where LocalPort == 3389 summarize ActionTypes = make_set(ActionType) by RemoteIP where set_has_element(ActionTypes, "ConnectionAttempt")</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
		<pre>and set_has_element(ActionTypes, "InboundConnectionAccepted") project RemoteIP; rdp_scanners evaluate ipv4_lookup(GeoTable, RemoteIP, network) summarize dcount(country_name)</pre>	
RESULT		<pre>dcount_country_name 11</pre>	
REMEDIATION		Implement geo-blocking as a defense-in-depth measure. Allow only expected business geographies (US) for RDP. All other countries should be blocked at NSG.	

PHASE 3 — AUTHENTICATION & BRUTE FORCE

F11	How many externally sourced authentication events were recorded?	HIGH	ANSWERED
ANSWER	693 events		
MITRE	T1110.001 — Brute Force: Password Guessing		
ANALYSIS	693 total external authentication events in 14 days — approximately 50/day. This volume confirms continuous automated brute-force activity, not targeted manual attempts.		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" count</pre>		
RESULT	<pre>count_ 693</pre>		
REMEDIATION	Implement account lockout policy (e.g., 5 failed attempts → 30 min lockout). Enable Azure AD Identity Protection for anomalous login detection.		

F12	How many RDP-related authentication events (Network + RemoteInteractive)?	HIGH	ANSWERED
ANSWER	675 events		
MITRE	T1110.001 — Brute Force: Password Guessing T1021.001 — Remote Services: RDP		
ANALYSIS	675 of 693 total external auth events (97%) are RDP-related. Hint confirmed: LogonType in ('Network', 'RemoteInteractive') captures the full RDP authentication surface.		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02"</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
	<pre> where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") count</pre>	
RESULT	<pre>count_ 675</pre>	
REMEDIATION	Enforce MFA on all RDP accounts. Consider Just-In-Time VM access in Azure Defender for Cloud to eliminate persistent RDP exposure.	

F13	Which authentication outcome was most frequently recorded?	HIGH	ANSWERED
ANSWER	LogonFailed		
MITRE	T1110.001 — Brute Force: Password Guessing		
ANALYSIS	646 failures vs 29 successes. The high failure rate is classic credential stuffing — automated tools cycling through password lists until one works.		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") summarize count() by ActionType order by count_ desc</pre>		
RESULT	<pre>ActionType count_ LogonFailed 646 LogonSuccess 29</pre>		
REMEDIATION	Enforce strong password policy (16+ chars, complexity). Deploy Azure AD Password Protection to block common/leaked passwords. Review all LogonSuccess events for anomalies.		

F14	What was the most common failure reason?	MEDIUM	ANSWERED
ANSWER	InvalidUserNameOrPassword		
MITRE	T1110.001 — Brute Force: Password Guessing		
ANALYSIS	637 of 646 failures (98.6%) are pure credential guessing — no locked accounts, no expired passwords, just an attacker cycling through passwords until the weak one matched.		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive")</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
	<pre> where ActionType == "LogonFailed" summarize count() by FailureReason order by count_ desc</pre>		
RESULT	<pre>FailureReason count_ InvalidUserNameOrPassword 637 Other 9</pre>		
REMEDIATION	The account 'vmadminusername' is a dangerously guessable admin account name. Rename all admin accounts to non-obvious names. Enforce Credential Guard.		

F15	How many unique countries in RDP auth events?	MEDIUM	ANSWERED
ANSWER	17 countries		
MITRE	T1110 — Brute Force T1133 — External Remote Services		
ANALYSIS	17 countries attempted authentication. This geographic spread indicates distributed botnet infrastructure, not a single operator manually trying passwords.		
KQL QUERY	<pre>let GeoTable = externaldata(network:string, geoname_id:long, continent_code:string, continent_name:string, country_iso_code:string, country_name:string) [@"https://raw.githubusercontent.com/datasets/geoip2- ipv4/main/data/geoip2-ipv4.csv"] with (format="csv"); DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") distinct RemoteIP evaluate ipv4_lookup(GeoTable, RemoteIP, network) summarize dcount(country_name)</pre>		
RESULT	<pre>dcount_country_name 17</pre>		
REMEDiation	Implement geo-fencing: allow RDP authentication attempts from US only. Block all non-US auth at NSG or Conditional Access level.		

F16	How many countries had at least one successful authentication?	CRITICAL	ANSWERED
ANSWER	2 countries		
MITRE	T1078 — Valid Accounts T1021.001 — RDP		
ANALYSIS	Only 2 countries achieved successful logons. One is expected (US), one is anomalous (Uruguay — no PHTG presence). The anomaly is the threat.		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
KQL QUERY	<pre>let GeoTable = externaldata(network:string, geoname_id:long, continent_code:string, continent_name:string, country_iso_code:string, country_name:string) [@"https://raw.githubusercontent.com/datasets/geoip2- ipv4/main/data/geoip2-ipv4.csv"] with (format="csv"); DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") where ActionType == "LogonSuccess" distinct RemoteIP evaluate ipv4_lookup(GeoTable, RemoteIP, network) summarize dcount(country_name)</pre>		
RESULT	<pre>dcount_country_name 2</pre>		
REMEDIATION	Configure Azure Conditional Access: block logons from any country outside US. Alert on any first-time country logon success.		

F17	Which countries had successful RDP authentication?	CRITICAL	ANSWERED
ANSWER	Uruguay, United States		
MITRE	T1078 — Valid Accounts T1021.001 — Remote Desktop Protocol		
ANALYSIS	4 IPs achieved successful logon — 2 from Uruguay (attacker), 2 from United States (expected). The Uruguayan IPs are the threat actor.		
KQL QUERY	<pre>let GeoTable = externaldata(...) [...] with (format="csv"); DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") where ActionType == "LogonSuccess" distinct RemoteIP evaluate ipv4_lookup(GeoTable, RemoteIP, network) project RemoteIP, country_name</pre>		
RESULT	<pre>RemoteIP country_name 173.244.55.128 Uruguay 173.244.55.131 Uruguay 142.111.152.58 United States 173.239.218.124 United States</pre>		
REMEDIATION	Block 173.244.55.0/24 immediately at NSG and firewall. Reset vmadminusername password and force MFA enrollment. Review all sessions from US IPs to confirm legitimacy.		

PHTG // THREAT HUNT 03 // CONFIDENTIAL			azwks-phtg-02 Dec 2025
F18	Which country is outside PHTG's expected operating region?	CRITICAL	ANSWERED
ANSWER	Uruguay		
MITRE	T1078 — Valid Accounts T1071 — Application Layer Protocol		
ANALYSIS	<i>PHTG has no employees, contractors or systems in Uruguay. Successful RDP auth from this country has zero legitimate business justification. This is the primary threat actor.</i>		
KQL QUERY	<pre>-- Analytical finding - PHTG operates exclusively in the United States. -- Any non-US successful authentication is anomalous by policy.</pre>		
RESULT	<pre>Uruguay - no PHTG business presence Attacker IPs: 173.244.55.128, 173.244.55.131</pre>		
REMEDIATION	Establish baseline geographic access policy in writing. Implement automated alerting for any logon success from outside defined business geographies.		

F19	Which account was used in the Uruguay authentication?	CRITICAL	ANSWERED
ANSWER	vmadminusername		
MITRE	T1078.001 — Valid Accounts: Default Accounts		
ANALYSIS	<i>The account name 'vmadminusername' is a textbook weak admin account — predictable name, likely a default or placeholder that was never renamed or hardened.</i>		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") where ActionType == "LogonSuccess" where RemoteIP in ("173.244.55.128", "173.244.55.131") distinct AccountName</pre>		
RESULT	<pre>AccountName vmadminusername</pre>		
REMEDIATION	Immediately disable vmadminusername. Create uniquely named admin accounts with strong passwords. Enforce privileged identity management (PIM) for all admin access.		

F20	How many successful RDP auth events from Uruguay?	CRITICAL	ANSWERED
ANSWER	23 successful logon events		
MITRE	T1078 — Valid Accounts T1021.001 — RDP		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
ANALYSIS	23 successful logons across multiple sessions — the attacker returned repeatedly, confirming this was not a one-time accident but an active, persistent intrusion campaign.	
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") where ActionType == "LogonSuccess" where RemoteIP in ("173.244.55.128", "173.244.55.131") count</pre>	
RESULT	<pre>count_ 23</pre>	
REMEDIATION	Review all 23 sessions for data exfiltration, lateral movement and persistence mechanisms. Assume all data accessible to vmadminusername has been compromised.	

F21	What IP made the first successful RDP auth from Uruguay?	CRITICAL	ANSWERED
ANSWER	173.244.55.131		
MITRE	T1021.001 — Remote Services: RDP		
ANALYSIS	First access at 05:47 UTC — early morning, consistent with attacker timezone offset from South America. Source device name 'sarah-che' is significant — matches the victim's name.		
KQL QUERY	<pre>DeviceLogonEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where RemoteIPType == "Public" where LogonType in ("Network", "RemoteInteractive") where ActionType == "LogonSuccess" where RemoteIP in ("173.244.55.128", "173.244.55.131") order by TimeGenerated asc take 1 project RemoteIP, TimeGenerated</pre>		
RESULT	<pre>RemoteIP TimeGenerated 173.244.55.131 2025-12-12T05:47:45.426Z -- Source device: sarah-che (from logon details)</pre>		
REMEDIATION	Preserve full forensic image of VM before remediation. The 'sarah-che' device name may indicate the attacker used the victim's own leaked credentials or device names found in notes_sarah.txt.		

F22	What is the other attacker IP from Uruguay?	CRITICAL	ANSWERED
ANSWER	173.244.55.128		
MITRE	T1021.001 — Remote Services: RDP		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
ANALYSIS	Both IPs are in the same /24 subnet as the C2 server (173.244.55.130). This is a single threat actor using multiple IPs from the same infrastructure block.	
KQL QUERY	<pre>-- Analytical -- derived from F17 and F21 results. -- All successful Uruguay IPs: 173.244.55.128 and 173.244.55.131</pre>	
RESULT	<pre>173.244.55.128 - Phase 1 RDP sessions (RemoteInteractive) 173.244.55.131 - First auth + C2 subnet Both in /24: 173.244.55.0/24 (same infrastructure)</pre>	
REMEDATION	Block entire 173.244.55.0/24 range — all three attacker IPs share this subnet. Submit to threat intelligence sharing platforms.	

PHASE 4 — POST-ACCESS OPERATOR BEHAVIOUR

F23	What is the first process indicating human interaction after initial access?	HIGH	ANSWERED
ANSWER	notepad.exe		
MITRE	T1083 — File and Directory Discovery		
ANALYSIS	notepad.exe opened with no file argument at 13:35:54 — a human manually launching Notepad, distinct from the scripted PowerShell noise (calc.exe, mspaint.exe). This marks the start of interactive operator behaviour.		
KQL QUERY	<pre>DeviceProcessEvents where TimeGenerated between (datetime(2025-12-12T13:32:00Z) .. datetime(2025-12-12T15:00:00Z)) where DeviceName has "azwks-phtg-02" where InitiatingProcessAccountName =~ "vmadminusername" where FileName != "msedge.exe" project TimeGenerated, FileName, ProcessCommandLine, InitiatingProcessFileName order by TimeGenerated asc take 20</pre>		
RESULT	<pre>TimeGenerated FileName InitiatingProcess 2025-12-12T13:35:54Z notepad.exe powershell.exe -- First human-interactive process (no file arg = manual open)</pre>		
REMEDATION	Monitor for Notepad/text editor use by admin accounts outside business hours. Implement User Entity Behaviour Analytics (UEBA) to baseline and alert on anomalous activity patterns.		

F24	Which text file contained security-relevant content?	CRITICAL	ANSWERED
ANSWER	notes_sarah.txt		
MITRE	T1005 — Data from Local System T1083 — File and Directory Discovery		

ANALYSIS	<i>notes_sarah.txt is identified as security-relevant because 'sarah' matches the attacker's source device name 'sarah-che' — suggesting the attacker was looking for notes tied to a specific insider or credential owner. The file may have contained passwords, infrastructure details or escalation paths.</i>																		
KQL QUERY	<pre>DeviceProcessEvents where TimeGenerated between (datetime(2025-12-12T13:32:00Z) .. datetime(2025-12-12T15:00:00Z)) where DeviceName has "azwks-phtg-02" where InitiatingProcessAccountName =~ "vmadminusername" where FileName == "notepad.exe" project TimeGenerated, ProcessCommandLine, InitiatingProcessFileName order by TimeGenerated asc</pre>																		
RESULT	<table><thead><tr><th>TimeGenerated</th><th>ProcessCommandLine</th></tr></thead><tbody><tr><td>InitiatingProcess</td><td></td></tr><tr><td>13:46:07</td><td>NOTEPAD.EXE C:\...\PHTG\Notes 12122025.txt</td></tr><tr><td>explorer.exe</td><td></td></tr><tr><td>13:46:14</td><td>NOTEPAD.EXE C:\...\PHTG\notes_sarah.txt</td></tr><tr><td>explorer.exe</td><td></td></tr><tr><td>13:46:19</td><td>NOTEPAD.EXE C:\...\PHTG\PHTG_Project_Notes_azwks-phtg-02.txt explorer.exe</td></tr><tr><td>13:46:23</td><td>NOTEPAD.EXE C:\...\PHTG\PHTG_ToDo_azwks-phtg-02.txt</td></tr><tr><td>explorer.exe</td><td></td></tr></tbody></table>	TimeGenerated	ProcessCommandLine	InitiatingProcess		13:46:07	NOTEPAD.EXE C:\...\PHTG\Notes 12122025.txt	explorer.exe		13:46:14	NOTEPAD.EXE C:\...\PHTG\notes_sarah.txt	explorer.exe		13:46:19	NOTEPAD.EXE C:\...\PHTG\PHTG_Project_Notes_azwks-phtg-02.txt explorer.exe	13:46:23	NOTEPAD.EXE C:\...\PHTG\PHTG_ToDo_azwks-phtg-02.txt	explorer.exe	
TimeGenerated	ProcessCommandLine																		
InitiatingProcess																			
13:46:07	NOTEPAD.EXE C:\...\PHTG\Notes 12122025.txt																		
explorer.exe																			
13:46:14	NOTEPAD.EXE C:\...\PHTG\notes_sarah.txt																		
explorer.exe																			
13:46:19	NOTEPAD.EXE C:\...\PHTG\PHTG_Project_Notes_azwks-phtg-02.txt explorer.exe																		
13:46:23	NOTEPAD.EXE C:\...\PHTG\PHTG_ToDo_azwks-phtg-02.txt																		
explorer.exe																			
REMEDIATION	Classify and protect sensitive documents — implement AIP/MIP labels. Store credentials only in PAM vaults, never in text files. Audit all documents accessible to vmadminusername.																		

PHASE 5 — PAYLOAD DEPLOYMENT & EVASION

F25	What is the first filename that turns the payload into a Windows executable?	CRITICAL	ANSWERED									
ANSWER	Sarah_Chen_Notes.exe											
MITRE	T1036.003 — Masquerading: Rename System Utilities T1027 — Obfuscated Files or Information											
ANALYSIS	The rename from .Txt to .exe occurred at exactly 14:18:38 — just minutes after Defender was switched to passive mode (14:18). The attacker knew the AV state before executing.											
KQL QUERY	<pre>DeviceFileEvents where TimeGenerated between (datetime(2025-12-12) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where ActionType == "FileRenamed" where FileName endswith ".exe" where InitiatingProcessAccountName =~ "vmadminusername" project TimeGenerated, FileName, PreviousFileName, FolderPath, InitiatingProcessFileName order by TimeGenerated asc</pre>											
RESULT	<table><tr><th>TimeGenerated</th><th>FileName</th><th>PreviousFileName</th></tr><tr><td>2025-12-12T14:18:38Z</td><td>Sarah_Chen_Notes.exe</td><td>Sarah_Chen_Notes.exe.Txt</td></tr><tr><td colspan="3">-- First rename to .exe extension at 14:18:38 UTC</td></tr></table>			TimeGenerated	FileName	PreviousFileName	2025-12-12T14:18:38Z	Sarah_Chen_Notes.exe	Sarah_Chen_Notes.exe.Txt	-- First rename to .exe extension at 14:18:38 UTC		
TimeGenerated	FileName	PreviousFileName										
2025-12-12T14:18:38Z	Sarah_Chen_Notes.exe	Sarah_Chen_Notes.exe.Txt										
-- First rename to .exe extension at 14:18:38 UTC												

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
REMEDIATION	Enable tamper protection on Defender to prevent passive mode switching. Alert on any .exe rename events in user document directories.		

F26	What double-extension filename was used for evasion?	CRITICAL	ANSWERED
ANSWER	Sarah_Chen_Notes.exe.Txt		
MITRE	T1027.002 — Obfuscated Files: Software Packing T1036 — Masquerading		
ANALYSIS	Classic double-extension attack: file is actually Sarah_Chen_Notes.exe masquerading as a .Txt. Windows Explorer hides known extensions by default, making this appear as a text file to casual inspection.		
KQL QUERY	<pre>-- Derived from F25 query results. -- PreviousFileName column shows the double-extension evasion filename.</pre>		
RESULT	<pre>PreviousFileName: Sarah_Chen_Notes.exe.Txt -- True extension: .exe (hidden by .Txt suffix) -- Windows hides known extensions → appears as 'Sarah_Chen_Notes.exe'</pre>		
REMEDIATION	Enforce 'Show file extensions' via Group Policy for all users. Deploy endpoint protection that inspects file content (magic bytes) rather than relying on extension. Alert on .exe.Txt pattern.		

F27	What is the SHA256 of the payload file?	CRITICAL	ANSWERED
ANSWER	224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695		
MITRE	T1036.003 — Masquerading T1027 — Obfuscated Files		
ANALYSIS	SHA256 is consistent across all rename events — this is definitively the same Meterpreter binary throughout the entire attack chain. Hash never changes regardless of filename.		
KQL QUERY	<pre>DeviceFileEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where FileName in ("Sarah_Chen_Notes.exe", "Sarah_Chen_Notes.exe.Txt", "PHTG.exe") where isnotempty(SHA256) project TimeGenerated, FileName, SHA256, FolderPath, ActionType order by TimeGenerated asc</pre>		
RESULT	<pre>FileName SHA256 (truncated) Sarah_Chen_Notes.exe.Txt 224462ce5e3304e3...2687e695 Sarah_Chen_Notes.exe 224462ce5e3304e3...2687e695 PHTG.exe 224462ce5e3304e3...2687e695 -- Same hash across all 5 rename events - identical file.</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL	azwks-phtg-02 Dec 2025
REMEDIATION	Submit SHA256 to VirusTotal, MISP, and your EDR threat intel feed. Add to blocklist across all PHTG endpoints. Search for this hash across all other PHTG devices.

F28	What is the final observed filename for this payload hash?	CRITICAL	ANSWERED
ANSWER	PHTG.exe		
MITRE	T1036.003 — Masquerading: Rename System Utilities T1574 — Hijack Execution Flow		
ANALYSIS	<i>PHTG.exe placed in C:\ProgramData\PHTG\HealthCloud\ — the legitimate HealthCloud service path. Any analyst seeing 'PHTG.exe' in the HealthCloud directory would assume it's legitimate.</i>		
KQL QUERY	<pre>DeviceFileEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" where isnotempty(SHA256) project TimeGenerated, FileName, SHA256, FolderPath, ActionType order by TimeGenerated asc</pre>		
RESULT	<pre>TimeGenerated FileName FolderPath ActionType 2025-12-13T10:16:22Z PHTG.exe C:\ProgramData\PHTG\HealthCloud\PHTG.exe FileRenamed -- Final rename — now masquerading as HealthCloud service binary.</pre>		
REMEDIATION	Implement file integrity monitoring (FIM) on C:\ProgramData\PHTG\. Any new .exe file in this directory should trigger a HIGH alert. Maintain a whitelist of known-good HealthCloud binaries with hashes.		

F29	What malware family does Defender classify this file as?	CRITICAL	ANSWERED
ANSWER	Meterpreter		
MITRE	T1059.001 — PowerShell T1071.001 — Web Protocols		
ANALYSIS	<i>Meterpreter is the post-exploitation framework built into Metasploit. It provides a fully-featured remote shell with file system access, screenshot capability, keylogging, and lateral movement tools. The attacker has full command execution on this host.</i>		
KQL QUERY	<pre>DeviceEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" project TimeGenerated, ActionType, AdditionalFields, FileName order by TimeGenerated asc</pre>		
RESULT	<pre>TimeGenerated ActionType AdditionalFields (truncated)</pre>		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025	
	<pre>2025-12-12T14:11:02Z OtherAlertRelatedActivity Defender detected Trojan:Win32/Meterpreter.RPZ!MTB 2025-12-12T14:18:52Z AntivirusDetectionActionType ThreatName: Trojan:Win32/Meterpreter.RPZ!MTB ReportSource: Windows Defender Antivirus passive mode</pre>		
REMEDIATION	Treat this as a full compromise. Assume all data on the system has been exfiltrated. Begin incident response: isolate, image, investigate, remediate, harden, restore.		

F30	What Defender state change allowed the payload to execute?	CRITICAL	ANSWERED
ANSWER	Passive mode		
MITRE	T1562.001 — Impair Defenses: Disable or Modify Tools		
ANALYSIS	Defender quarantined the payload 3 times (14:11, 14:12, 14:17). At 14:18, the attacker switched Defender to passive mode — detection-only, no blocking. This is the critical turning point of the entire attack.		
KQL QUERY	<pre>DeviceEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" project TimeGenerated, ActionType, AdditionalFields, FileName order by TimeGenerated asc</pre>		
RESULT	<pre>Before 14:17 — ActionType: OtherAlertRelatedActivity Defender detected AND QUARANTINED (active mode) After 14:18 — ActionType: AntivirusDetectionActionType ReportSource: 'Windows Defender Antivirus passive mode' Defender detected but DID NOT BLOCK (passive mode)</pre>		
REMEDIATION	Enable Defender Tamper Protection immediately — prevents passive mode switching without MDE console approval. Alert on any Defender mode changes. Require MFA + change control approval for AV configuration changes.		

PHASE 6 — EXECUTION, PERSISTENCE & C2

F31	What filename did the payload run under in Phase 1?	CRITICAL	ANSWERED
ANSWER	Sarah_Chen_Notes.exe		
MITRE	T1204.002 — User Execution: Malicious File		
ANALYSIS	explorer.exe as the initiating process confirms the attacker manually double-clicked the file from Windows Explorer — direct operator interaction, not scripted execution.		
KQL QUERY			

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025																
	<pre>DeviceProcessEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" project TimeGenerated, FileName, ProcessCommandLine, InitiatingProcessFileName order by TimeGenerated asc</pre>																	
RESULT	<table><thead><tr><th>TimeGenerated</th><th>FileName</th><th>InitiatingProcess</th></tr></thead><tbody><tr><td>2025-12-12T14:18:51Z</td><td>Sarah_Chen_Notes.exe</td><td>explorer.exe</td></tr><tr><td>2025-12-12T14:20:37Z</td><td>Sarah_Chen_Notes.exe</td><td>explorer.exe</td></tr><tr><td>2025-12-12T14:22:11Z</td><td>Sarah_Chen_Notes.exe</td><td>explorer.exe</td></tr><tr><td>2025-12-13T10:13:18Z</td><td>Sarah_Chen_Notes.exe</td><td>explorer.exe</td></tr></tbody></table> -- Phase 1: explorer.exe = manual double-click execution			TimeGenerated	FileName	InitiatingProcess	2025-12-12T14:18:51Z	Sarah_Chen_Notes.exe	explorer.exe	2025-12-12T14:20:37Z	Sarah_Chen_Notes.exe	explorer.exe	2025-12-12T14:22:11Z	Sarah_Chen_Notes.exe	explorer.exe	2025-12-13T10:13:18Z	Sarah_Chen_Notes.exe	explorer.exe
TimeGenerated	FileName	InitiatingProcess																
2025-12-12T14:18:51Z	Sarah_Chen_Notes.exe	explorer.exe																
2025-12-12T14:20:37Z	Sarah_Chen_Notes.exe	explorer.exe																
2025-12-12T14:22:11Z	Sarah_Chen_Notes.exe	explorer.exe																
2025-12-13T10:13:18Z	Sarah_Chen_Notes.exe	explorer.exe																
REMEDIATION	Enable application control (AppLocker / WDAC) to prevent execution of unsigned binaries from user Documents directories. Block explorer.exe from launching unsigned .exe files.																	

F32	Which process initiated Phase 2 executions?	CRITICAL	ANSWERED
ANSWER	cmd.exe		
MITRE	T1059.003 — Windows Command Shell T1543 — Create or Modify System Process		
ANALYSIS	Phase 2 uses cmd.exe launching PHTG.exe via Launch.bat — this is persistence. The shift from manual explorer.exe execution to scripted cmd.exe execution confirms the attacker established an automated execution mechanism.		
KQL QUERY	<pre>DeviceProcessEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" where InitiatingProcessFileName == "cmd.exe" project TimeGenerated, FileName, ProcessCommandLine, InitiatingProcessCommandLine order by TimeGenerated asc</pre>		
RESULT	<pre>TimeGenerated FileName InitiatingProcessCommandLine 2025-12-13T10:21:48Z PHTG.exe cmd.exe /c "C:\ProgramData\PHTG\HealthCloud\Launch.bat" 2025-12-13T10:22:36Z PHTG.exe cmd.exe /c "C:\ProgramData\PHTG\HealthCloud\Launch.bat" -- Phase 2: cmd.exe via Launch.bat = automated/persistent execution</pre>		
REMEDIATION	Monitor for cmd.exe /c batch file execution patterns in ProgramData directories. Implement script block logging for all cmd.exe and PowerShell invocations.		

F33	What is the full path of the .bat persistence launcher?	CRITICAL	ANSWERED
ANSWER	C:\ProgramData\PHTG\HealthCloud\Launch.bat		

PHTG // THREAT HUNT 03 // CONFIDENTIAL		azwks-phtg-02 Dec 2025
MITRE	T1543.003 — Windows Service T1574.010 — Hijack Execution Flow	
ANALYSIS	Launch.bat was placed inside the legitimate HealthCloud service directory — the attacker exploited the newly-deployed service as cover. Any scheduled task or service calling HealthCloud processes would also execute the malware.	
KQL QUERY	<pre>-- Derived from F32 InitiatingProcessCommandLine field: cmd.exe /c ""C:\ProgramData\PHTG\HealthCloud\Launch.bat"" -- Confirm with: DeviceFileEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where FileName == "Launch.bat" project TimeGenerated, FileName, FolderPath, ActionType, InitiatingProcessFileName</pre>	
RESULT	<pre>Full path: C:\ProgramData\PHTG\HealthCloud\Launch.bat Initiating process for PHTG.exe: cmd.exe Location: Legitimate HealthCloud service directory</pre>	
REMEDIATION	Delete Launch.bat and PHTG.exe immediately. Audit all scheduled tasks and services pointing to HealthCloud directory. Reimage the VM from a clean snapshot predating Dec 12.	

F34	What external IP did the payload connect to for C2?	CRITICAL	ANSWERED																
ANSWER	173.244.55.130																		
MITRE	T1095 — Non-Application Layer Protocol T1572 — Protocol Tunneling																		
ANALYSIS	<i>The C2 IP (173.244.55.130) is in the same /24 subnet as the RDP attacker IPs (173.244.55.128, .131). This is a single attacker operation using coordinated infrastructure. All callbacks confirmed on port 4444.</i>																		
KQL QUERY	<pre>DeviceNetworkEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where InitiatingProcessSHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" where RemoteIPType == "Public" project TimeGenerated, RemoteIP, RemotePort, InitiatingProcessFileName order by TimeGenerated asc</pre>																		
RESULT	<table><tr><th>TimeGenerated</th><th>RemoteIP</th><th>RemotePort</th><th>FileName</th></tr><tr><td>2025-12-12T14:19:12Z</td><td>173.244.55.130</td><td>4444</td><td>Sarah_Chen_Notes.exe</td></tr><tr><td>2025-12-13T10:13:39Z</td><td>173.244.55.130</td><td>4444</td><td>Sarah_Chen_Notes.exe</td></tr><tr><td>2025-12-13T10:22:09Z</td><td>173.244.55.130</td><td>4444</td><td>PHTG.exe</td></tr></table>			TimeGenerated	RemoteIP	RemotePort	FileName	2025-12-12T14:19:12Z	173.244.55.130	4444	Sarah_Chen_Notes.exe	2025-12-13T10:13:39Z	173.244.55.130	4444	Sarah_Chen_Notes.exe	2025-12-13T10:22:09Z	173.244.55.130	4444	PHTG.exe
TimeGenerated	RemoteIP	RemotePort	FileName																
2025-12-12T14:19:12Z	173.244.55.130	4444	Sarah_Chen_Notes.exe																
2025-12-13T10:13:39Z	173.244.55.130	4444	Sarah_Chen_Notes.exe																
2025-12-13T10:22:09Z	173.244.55.130	4444	PHTG.exe																
REMEDIATION	Block 173.244.55.0/24 at firewall. Implement outbound firewall rules — workstations should not initiate outbound connections on port 4444. Deploy network detection for Meterpreter C2 patterns.																		

PHTG // THREAT HUNT 03 // CONFIDENTIAL			azwks-phtg-02 Dec 2025
F35	Where is the C2 infrastructure located?	CRITICAL	ANSWERED
ANSWER	Uruguay, South America		
MITRE	T1583.003 — Acquire Infrastructure: Virtual Private Server		
ANALYSIS	<i>The entire attacker infrastructure (RDP access IPs .128/.131 and C2 IP .130) is in Uruguay — a single geographic threat actor. All infrastructure is in the same /24 block, suggesting a dedicated VPS or small infrastructure cluster.</i>		
KQL QUERY	<pre>let GeoTable = externaldata(network:string, geoname_id:long, continent_code:string, continent_name:string, country_iso_code:string, country_name:string) [@"https://raw.githubusercontent.com/datasets/geoip2- ipv4/main/data/geoip2-ipv4.csv"] with (format="csv"); print ip = "173.244.55.130" evaluate ipv4_lookup(GeoTable, ip, network) project country_name, continent_name</pre>		
RESULT	<pre>country_name continent_name Uruguay South America</pre>		
REMEDIATION	File threat intelligence report with relevant ISACs. Submit C2 IP to abuse contacts for the Uruguayan hosting provider. Share IOCs via STIX/TAXII with sector peers.		

F36	What remote port did the post-execution C2 use?	HIGH	ANSWERED
ANSWER	4444		
MITRE	T1095 — Non-Application Layer Protocol		
ANALYSIS	<i>Port 4444 is Meterpreter's default C2 port and is not commonly used for legitimate business traffic. The attacker did not bother changing it from the default — indicating either low operational security or confidence that outbound traffic wasn't monitored.</i>		
KQL QUERY	<pre>-- From F34 results - RemotePort column: DeviceNetworkEvents where DeviceName has "azwks-phtg-02" where InitiatingProcessSHA256 == "224462ce5e3304e3fd0875..." where RemoteIPType == "Public" project RemoteIP, RemotePort, InitiatingProcessFileName</pre>		
RESULT	<pre>RemotePort (all 3 callback events) 4444 -- Metasploit/Meterpreter default C2 port</pre>		
REMEDIATION	Block outbound port 4444 at perimeter firewall as a default policy. Enable full outbound traffic monitoring — alert on any non-standard port outbound from corporate workstations.		

PHTG // THREAT HUNT 03 // CONFIDENTIAL			azwks-phtg-02 Dec 2025
F37	What legitimate service was exploited for persistence camouflage?	CRITICAL	ANSWERED
ANSWER	HealthCloud		
MITRE	T1574.010 — Hijack Execution Flow T1543.003 — Create or Modify System Process		
ANALYSIS	<i>HealthCloud was deployed just 2 days before the attacker used it. The attacker may have known about HealthCloud from the LinkedIn post or from notes_sarah.txt. This is a sophisticated persistence choice — a new service blends in, has fewer baseline comparisons, and is less likely to trigger alerts.</i>		
KQL QUERY	<pre>DeviceFileEvents where TimeGenerated between (datetime(2025-12-09) .. datetime(2025-12-23)) where DeviceName has "azwks-phtg-02" where SHA256 == "224462ce5e3304e3fd0875eeabc829810a894911e3d4091d4e60e67a2687e695" where isnotempty(SHA256) project TimeGenerated, FileName, SHA256, FolderPath, ActionType order by TimeGenerated asc</pre>		
RESULT	<pre>TimeGenerated FileName FolderPath 2025-12-13T10:14:41Z Sarah_Chen_Notes.exe C:\ProgramData\PHTG\HealthCloud\ 2025-12-13T10:16:22Z PHTG.exe C:\ProgramData\PHTG\HealthCloud\ -- HealthCloud was deployed Dec 11 - attacker used the NEW service as cover</pre>		
REMEDIATION	Implement hash-based allow-listing for HealthCloud binaries immediately. Monitor HealthCloud directory with FIM. New service rollouts must include security baseline validation and directory ACL hardening before deployment.		

10. REMEDIATION & RECOVERY PLAN

Prioritized action plan. Complete Phase 1 before beginning Phase 2.

PHASE 1 — IMMEDIATE (Within 24 Hours)

#	Action	Owner / Tool
1	ISOLATE azwks-phtg-02 — disconnect from network, preserve for forensics	Azure Portal → NSG → Deny All / SecOps
2	BLOCK 173.244.55.0/24 at perimeter firewall and all NSGs	Network Team / Azure Firewall
3	RESET vmadminusername password + disable account pending review	IAM Team / Azure AD
4	RE-ENABLE Defender active mode + enable Tamper Protection	SecOps / MDE Console
5	DELETE Launch.bat and PHTG.exe from HealthCloud directory	IR Team (forensic copy first)
6	REVOKE all active RDP sessions on azwks-phtg-02	Azure Portal / SecOps

PHASE 2 — SHORT TERM (Within 1 Week)

#	Action	Owner / Tool
7	Remove public IP from azwks-phtg-02 — deploy Azure Bastion for admin RDP	Cloud Team / Azure Portal
8	Enforce MFA on ALL accounts with RDP privileges	IAM Team / Azure AD MFA
9	Implement NSG rule: deny all inbound 3389 from internet	Network Team / Azure NSG
10	Rename all generic admin accounts (vmadmin*, admin*, administrator*)	IAM Team
11	Search for SHA256 hash across all other PHTG endpoints in MDE	SecOps / MDE Hunt
12	Audit HealthCloud directory — FIM baseline all legitimate binaries	SecOps / IR Team
13	Block outbound port 4444 at perimeter firewall	Network Team
14	Conduct OSINT review of all employee social media for infrastructure leaks	SecOps / HR

PHASE 3 — STRATEGIC (Within 30 Days)

#	Action	Owner / Tool
15	Deploy Privileged Identity Management (PIM) — JIT access for all admin roles	IAM Team / Azure PIM
16	Implement WDAC / AppLocker — block unsigned executables in user directories	SecOps / Endpoint Team

17	Enable UEBA in Microsoft Sentinel — baseline all admin account behaviour	SecOps / Sentinel
18	Deploy Azure Policy: deny public IP attachment to VMs without approval	Cloud Governance Team
19	Implement Conditional Access: block logons from non-US geographies	IAM Team / Azure AD CA
20	Security awareness training — OSINT risks, screenshot policy, social media	HR / Security Team
21	Credential hygiene audit — scan for credentials stored in text files on endpoints	SecOps / DLP
22	Establish incident response runbook for exposed-VM scenarios	SecOps / CISO

11. LESSONS LEARNED

Key takeaways for the PHTG security team and broader organization derived from this hunt.

#	Lesson	Detail & Implication
1	OSINT is a real attack vector <i>Social Media / LinkedIn</i>	A single LinkedIn post exposing an Azure portal screenshot was the root cause of a full compromise. Internal tooling, IP addresses, VM names, and subscription details should never appear in public posts. Implement a screenshot review policy and social media training for technical staff.
2	Public RDP = Internet Brute Force <i>Exposed Attack Surface</i>	Any VM with RDP exposed to the internet will be scanned and attacked within hours — not days. 173 unique IPs probed port 3389 across the 14-day window. Internet-facing admin protocols must be placed behind VPN, Bastion, or JIT access. There is no safe 'exposure window'.
3	Generic Admin Accounts Are Trivially Guessable <i>Credential Hygiene</i>	The account 'vmadminusername' was brute-forced in 637 attempts. Predictable naming conventions dramatically reduce brute-force effort. All privileged accounts must use non-obvious names, strong passphrases, and MFA. Treat account names as part of the secret.
4	AV in Passive Mode Provides Zero Protection <i>Defense Evasion / AV Bypass</i>	Defender successfully quarantined the Meterpreter payload 3 times in active mode. The moment it was switched to passive mode, the same payload executed freely. Tamper Protection must be enabled on all endpoints — AV mode changes require MDE console approval, not local admin rights.
5	Masquerading Exploits Trust in Known Directories <i>Masquerading / LOLBins</i>	Renaming malware to PHTG.exe and placing it in C:\ProgramData\PHTGHealthCloud — a directory belonging to a legitimate, recently-deployed service — made it nearly invisible to casual inspection. File Integrity Monitoring (FIM) with hash-based whitelisting of known binaries in service directories is essential.
6	Double-Extension Trick Still Works <i>Obfuscation / Evasion</i>	Sarah_Chen_Notes.exe.Txt exploited Windows' default behaviour of hiding known file extensions. To a user browsing the filesystem, this appeared to be a text file. Enforce 'Show file extensions' via Group Policy across all endpoints. Train users never to open unexpected files regardless of apparent extension.
7	ngrok Tunnels Bypass URL Reputation Filters <i>Payload Delivery / Tunneling</i>	The payload was delivered via a free ngrok subdomain — a legitimate service that proxies arbitrary content through a trusted domain. Standard URL reputation filtering cannot block this. Implement DNS/proxy inspection that blocks all *.ngrok-free.dev and *.ngrok.io domains unless explicitly approved by IT.

8	Behavioral Telemetry Catches What Signatures Miss <i>Detection Engineering</i>	SHA256-based hash tracking in MDE across DeviceFileEvents, DeviceProcessEvents, and DeviceNetworkEvents revealed the complete payload lifecycle — from download to C2. Without behavioral telemetry, the rename chain (Sarah_Chen_Notes.exe.Txt -> PHTG.exe) would have appeared as three unrelated files.
9	New Service Deployments Expand Attack Surface <i>Security Architecture</i>	HealthCloud was deployed on Dec 11 — one day before the attacker's first RDP session. The attacker may have learned about it from the LinkedIn post or from documents accessed on the VM. New service rollouts must include directory ACL hardening, FIM baseline capture, and security review before production deployment.
10	GeoIP Anomaly Detection is High-Value <i>Threat Detection</i>	The Uruguay successful logons stood out immediately when enriched with GeoIP data. PHTG operates only in the US — any non-US successful authentication is definitionally anomalous. Geographic baseline alerting (Conditional Access + Sentinel analytics) would have triggered on the very first Uruguay login at 05:47 UTC.

Report Completed By**Roshanak Khodaparast**

Threat Hunter — PHTG Security Operations

Hunt 03 // December 2025

Signature: _____

Reviewed & Approved By (CISO)

Chief Information Security Officer — PHTG

Date of Review: ____ / ____ / ____

Signature: _____

HUNT 03 COMPLETE — 38 / 38 FLAGS CAPTURED

*One LinkedIn post. One weak password. One unprotected VM. Full kill chain confirmed.***PHTG is actively compromised. Incident response must begin immediately.**